

PLATFORM AI TRANSFORMATION PLAYBOOK · ISSUE 03 OF 06

Identity is the first tool.

An agent on a shared human login is an unaccountable coworker.

03

AR

Akhilesh Ranjan Singh

Senior DevSecOps Engineer · github.com/iarsingh

Swipe →

Agent identity: do and avoid

DO

- ✓ One identity per agent, owned by a team
- ✓ Workload identity with short-lived tokens
- ✓ Least privilege per tool
- ✓ Revocable in five minutes

AVOID

- ✗ Shared human login
- ✗ Copied PAT in an env var
- ✗ One account for every agent
- ✗ Admin “just for the pilot”

Request path

- 1 Agent
- 2 Token broker
- 3 Policy check
- 4 Tool API
- 5 Audit log

Same shape as a Kubernetes service account calling a cloud API. The LLM does not get a pass.

Scope per tool

TOOL	ALLOWED	NEVER
Ticketing	Comment, draft	Close, delete
Git	Branch, open PR	Push to main
Kubernetes	get / list in one ns	exec, secrets, delete
Cloud	Read metrics	IAM, billing



The audit line every action needs

01 Who

Agent identity, plus the human or ticket it acted for.

02 What

Tool, arguments, target resource.

03 Result

Success, failure, what changed.

04 Approval

Reference to the human sign-off, if required.

THE READINESS TEST

Can you revoke it in five minutes?

If the answer involves finding whose laptop has the token, it is not ready.



KEY TAKEAWAY

Give agents their own identity, not yours.

- Workload identity, short-lived tokens
- Least privilege per tool
- Audit who, what, result, approval

YOUR TURN

Do agents in your shop have their own identity, or do they borrow yours?

FOLLOW AKHILESH RANJAN SINGH

Next in the series: #04 Appropriate autonomy

Save · Repost

